

• **Expediente N.º: EXP202307987**
Procedimiento Sancionador N.º PS/00395/2023

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: **A.A.A.** (en adelante, la parte reclamante) con fecha 27 de abril de 2023 interpuso reclamación ante la Agencia Española de Protección de Datos. La reclamación se dirige inicialmente contra el bufete **RECATALA AGRAMUNT ABOGADOS Y ECONOMISTAS** (en adelante, **Bufete-RA**).

Los motivos en que basa la reclamación son, literalmente, los siguientes:

"Este bufete ha tenido una brecha de seguridad al enviar información comercial de sus servicios y en vez de utilizar el campo Cco han utilizado el campo CC a la hora de incluir los mails de los destinatarios y hacer un envío masivo, entre los que me incluyo y dejando al descubierto el mail de todos, muchos de los cuales se puede inferir su identidad desde su mail que se ha hecho público y, por tanto, verse ésta comprometida."

Junto al escrito de reclamación, se aporta la cabecera del correo remitido el 24/04/2023, por ***EMAIL.1 a 95 destinatarios -entre los que se encuentra la reclamante- cuyas direcciones de correo electrónico aparecen visibles puesto que se han enviado como copia ordinaria (Cc), en lugar de en copia oculta (Cco). No obstante, no se aporta el contenido del email remitido.

SEGUNDO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante LOPDGDD), con fecha de 12/06/23 se dio traslado de dicha reclamación a la parte reclamada, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

El traslado, que se practicó conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP) mediante notificación electrónica a la dirección electrónica única de Bufete-RA, no fue recogido por el responsable, dentro del plazo de puesta a disposición, entendiéndose rechazada conforme a lo previsto en el art. 43.2 de la LPACAP en fecha 23/06/2023, como consta en el certificado que obra en el expediente.

Aunque la notificación se practicó válidamente por medios electrónicos, dándose por efectuado el trámite conforme a lo dispuesto en el artículo 41.5 de la LPACAP, a título informativo se envió una copia por correo postal que fue notificada fehacientemente en fecha 12/07/2023. En dicha notificación, se recordaba al Bufete-RA su obligación de

relacionarse electrónicamente con la Administración, y se le informaban de los medios de acceso a dichas notificaciones, reiterando que, en lo sucesivo, se le notificaría exclusivamente por medios electrónicos.

TERCERO: Con fecha 27 de julio de 2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación presentada por la parte reclamante.

CUARTO: Con fecha 31 de julio de 2023 se recibe en esta Agencia escrito de respuesta de **D. B.B.B.**, con **NIF ***NIF.1** que dice presentar alegaciones en su propio nombre y representación, pero realiza manifestaciones en defensa del Bufete-RA, indicando, en síntesis, que este despacho remite comunicaciones comerciales únicamente a los clientes que se registran en los diversos portales de pago a las que están suscritos como bufete de abogados y economistas, donde las personas que se suscriben registran sus datos personales, actuando al amparo del artículo 21 de la Ley 34/2002, de 11 de julio, sobre Servicios de la Sociedad de la Información (en adelante, LSSI).

Junto a las alegaciones se aporta copia de la cabecera y cuerpo del email remitido a la reclamante el 23 de abril de 2023. Se observa que éste ha sido remitido a 95 destinatarios cuyas direcciones electrónicas aparecen visibles sin utilizar la funcionalidad de copia oculta, y que se trata de un correo comercial que publicita los servicios profesionales del Bufete-Ra.

No se acompaña acreditación de la representación del mencionado Bufete-RA, frente al que se dirigía la reclamación.

QUINTO: Requerido el número de NIF del Bufete-RA a la Agencia Tributaria, ésta manifiesta con fecha de 24 de octubre de 2023 que no le constan datos a nombre de la referida entidad.

SEXTO: Con fecha de 25 de octubre de 2023, se remite escrito a **D. B.B.B.**, requiriendo al mismo para que acredite si actúa en nombre del referido Bufete-RA y aporte el número de NIF de la referida entidad. Remitido mediante notificación electrónica, este es rechazado, motivo por el cual se reitera el requerimiento por vía postal al domicilio del mismo, siendo este notificado finalmente con fecha de 12 de diciembre de 2023.

SÉPTIMO: Con fecha de 12 de diciembre de 2023, **D^a. C.C.C.**, con NIF *****NIF.2**, presenta escrito en nombre y representación de la entidad **COYARE SLU, con NIF B12931754**, en el que manifiesta que COYARE SLU se corresponde con el denominado Bufete-RA, y dice conceder poderes de representación a **B.B.B.**, para tomar decisiones en nombre y representación de la empresa. Se acompaña la escritura de constitución de la sociedad COYARE SLU, que acredita que la dicente es administradora única.

OCTAVO: De acuerdo con el informe recogido de la herramienta AXESOR con fecha de 26 de diciembre de 2023, la entidad COYARE SLU es una empresa pequeña constituida como sociedad limitada en el año 2014, cuyo último volumen de negocios es el que consta informado respecto al año 2019, que asciende a (...) euros.

NOVENO: Con fecha 27 de marzo de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a la parte reclamada por la comisión de una presunta infracción del artículo 5.1.f) del RGPD, con arreglo a lo dispuesto en los artículos 63 y 64 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), por la presunta infracción del Artículo 5.1.f) del RGPD y Artículo 32 del RGPD, tipificada en el Artículo 83.5 del RGPD y Artículo 83.4 del RGPD.

DÉCIMO: Con fecha de 18 de abril de 2024, se remite comunicación de inicio de procedimiento sancionador a la parte reclamante.

UNDÉCIMO: Notificado el citado acuerdo de inicio conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), B.B.B. presenta escrito de alegaciones en nombre y representación de la entidad reclamada, en el que, en síntesis, manifiesta lo siguiente:

- Cambio de interpretación del artículo 21.1 de la LSSI a raíz de la Sentencia de 15 de junio de 2011, que prohíbe el envío de comunicaciones comerciales que no hubieran sido solicitadas o expresamente autorizadas por sus destinatarios.

Según la reclamada, en dicha Sentencia, la A.N se aparta del requisito del consentimiento fijado por el artículo 21, y ha interpretado que en el caso de que un usuario recibiese varias comunicaciones comerciales de un tercero sin haber otorgado su consentimiento previo y expreso, pero sin oponerse al tratamiento, sólo sería sancionable la primera de las comunicaciones comerciales que se hubiese enviado, ya que al no haberse opuesto a la recepción de las siguientes comunicaciones comerciales, la AN considera que el usuario habría otorgado su consentimiento.

Se señala que, la Agencia Española de Protección de Datos (AEPD) ha comenzado a aplicar el criterio establecido por la AN desde septiembre de 2014, mencionando dos Resoluciones de la misma.

- Prescripción de las acciones y sanciones aplicables:

Se manifiesta al respecto que: *“Ante esta nueva interpretación de la LSSI, al ser únicamente la primera comunicación comercial la denunciante, si el usuario no se opusiese a las posteriores comunicaciones comerciales, cabría la posibilidad de que la acción para denunciar esa primera comunicación prescribiese, ya que el plazo de prescripción para las sanciones leves es de 6 meses desde la recepción de la primera comunicación (artículo 45 de la LSSI)”*. Entiende la reclamada que se trata de una infracción leve, por lo que estaría prescrita.

Se aclara al respecto que se entiende que el Sr. B.B.B. actúa como representante de la entidad reclamada, cuya representación se acreditó mediante escrito presentado por la administradora única de la sociedad durante la fase de traslado del expediente, si bien se advierte al mismo de la necesidad de presentar los escritos a través del registro electrónico como representante y no como interesado de la misma.

DUODÉCIMO: Con fecha de 4 de junio de 2024 se dicta Propuesta de Resolución sancionadora por la instructora del procedimiento, que se notifica con fecha de 15 de junio de 2024 a la parte reclamada, otorgándole un plazo de 10 días hábiles para que pueda alegar cuanto considerase en su defensa y presentar los documentos e informaciones que considere pertinentes.

A fecha de hoy, transcurrido el plazo otorgado, no se ha presentado alegaciones ni documentación alguna en contestación a la Propuesta de Resolución.

De las actuaciones practicadas en el presente procedimiento y de la documentación obrante en el expediente, han quedado acreditados los siguientes:

HECHOS PROBADOS

PRIMERO: Consta acreditado y reconocido por la parte reclamada que remitió con fecha de 24/04/2023, un correo electrónico que estaba dirigido a 95 destinatarios -entre los que se encuentra la reclamante- que contenía publicidad comercial de los servicios del Bufete-RA, en el que las 95 direcciones de correo electrónico aparecían visibles en copia ordinaria (Cc), en lugar de en copia oculta (Cco).

SEGUNDO: Que de acuerdo con la escritura aportada el 12 de diciembre de 2023 por **D^a. C.C.C.**, con NIF *****NIF.2**, la entidad reclamada, que presta sus servicios de asesoramiento legal bajo la denominación comercial de Bufete-Ra, está registrada y constituida bajo el nombre de COYARE SLU, con número de NIF **B12931754**.

TERCERO: De acuerdo con el informe emitido a través de la herramienta AXESOR con fecha de 26 de diciembre de 2023, la entidad COYARE SLU es una empresa pequeña constituida como sociedad limitada en el año 2014, cuyo último volumen de negocios es el que consta informado respecto al año 2019, que asciende a (...) euros.

FUNDAMENTOS DE DERECHO

I

Competencia y procedimiento.

De acuerdo con y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Directora de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se registrarán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II Cuestiones previas

La dirección de correo electrónico se considera un dato personal cuyo tratamiento se somete al régimen previsto en el RGPD, así como a sus disposiciones de desarrollo, de acuerdo con lo previsto en el artículo 4. 1, 2, y 7 el RGPD, que dispone lo siguiente:

“Artículo 4 Definiciones

A efectos del presente Reglamento se entenderá por:

1) «datos personales»: toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona;

2) «tratamiento»: cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción;(...)

7) «responsable del tratamiento» o «responsable»: la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros (...)

En el presente caso, de acuerdo con lo establecido en el artículo 4 del RGPD, de la documentación obrante en el presente expediente se deduce que la entidad COYARE SLU es responsable de haber tratado datos personales de 95 personas a las que se ha dirigido un correo electrónico comercial con publicidad de los servicios profesionales. Entidad que presta sus servicios de asesoramiento comercial y jurídico bajo la denominación comercial de Bufete-Ra, tal y como se deduce de la escritura de constitución de la sociedad y escrito presentado por la administradora única de la misma con fecha de 26 de junio de 2023.

De lo expuesto en el escrito de alegaciones presentado por el **Sr. B.B.B.** con fecha de 31 de julio de 2023, contestando al primer traslado que se realizó por esta Agencia al Bufete-RA, y que posteriormente se ha personado como representante de la misma

tras el inicio del presente expediente sancionador, se reconoce expresamente que el correo electrónico sin copia oculta al que se refiere el presente expediente se ha remitido en nombre del denominado Bufete-RA, para remitir publicidad de sus servicios profesionales. En dicho escrito se manifiesta que es práctica habitual de la empresa el remitir comunicaciones comerciales a los clientes que se registran en los diversos portales de pago a las que están suscritos como bufete de abogados y economistas, donde las personas que se suscriben registran sus datos personales. Por tanto, para remitir el correo electrónico masivo de 24 de abril de 2023 a 95 destinatarios, la entidad debió realizar varias operaciones de tratamiento de datos personales enumeradas en el referido artículo 4.2 del RGPD, tales como la recogida, registro, o extracción del correo electrónico de los 95 destinatarios, así como su difusión o comunicación por transmisión al remitirlas por correo electrónico masivo, sin utilizar la funcionalidad de copia oculta.

Posteriormente, el escrito de alegaciones contra el acuerdo de inicio que fue presentado por el mismo Sr. B.B.B., como representante de la entidad, no se han realizado manifestaciones que nieguen los hechos reconocidos en la primera contestación al traslado, poniendo en cuestión únicamente si con la remisión de tal correo electrónico se infringió el artículo 21.1. de la LSSI, y si esta estaba prescrita. Y desde entonces no se han formulado más alegaciones al respecto.

En su virtud, se confirma que la entidad reclamada realizó diversas operaciones de tratamiento de los datos personales de los destinatarios de dicho correo comercial, por lo que no cabe duda de que la normativa de protección de datos prevista en el RGPD le era de plena aplicación, con independencia de que éste deba sujetarse asimismo al cumplimiento de otras posibles normas de aplicación, como es la LSSI, cuando se remiten correos comerciales.

Por otra parte, la administradora única de la sociedad manifiesta en su escrito de 23 de junio de 2023 que la entidad COYARE SLU, actúa bajo la denominación de Bufete-RA, lo que concuerda con la documentación aportada por la misma, donde consta que COYARE SLU es una sociedad limitada que tiene entre su objeto social la actividad de prestar servicios profesionales de asesoramiento a empresas, profesionales y particulares. Por tanto, no cabe duda tampoco de que COYARE SLU ostenta personalidad jurídica y es la responsable de las operaciones de tratamiento de datos personales que realiza la referida entidad cuando remite los referidos correos comerciales, utilizando el nombre de Bufete-RA.

Por todo lo expuesto anteriormente, tal y como ha quedado confirmado tras la instrucción practicada, COYARE SLU era la responsable del tratamiento de los datos personales que fueron desvelados ilícitamente mediante el correo citado, por lo que es la responsable a la que debe dirigirse el presente procedimiento sancionador de acuerdo con lo previsto en el artículo 70. 1 a) de la Ley Orgánica 3/2018, de 5 de diciembre, de protección de datos personales y garantía de derechos digitales (en adelante, LOPDGD):

“Artículo 70. Sujetos responsables.

- 1. Están sujetos al régimen sancionador establecido en el Reglamento (UE) 2016/679 y en la presente ley orgánica: a) Los responsables de los*

tratamientos. b) Los encargados de los tratamientos. c) Los representantes de los responsables o encargados de los tratamientos no establecidos en el territorio de la Unión Europea. d) Las entidades de certificación. e) Las entidades acreditadas de supervisión de los códigos de conducta. (...)”.

III

Contestación de las alegaciones formuladas

Tras el inicio del presente procedimiento sancionador, que imputa a la reclamada la posible comisión de dos infracciones administrativas tipificadas en los artículos 5.1.f) y 32 del RGPD, la parte reclamada únicamente ha presentado un escrito de alegaciones contra el acuerdo de inicio, de fecha de 2 de mayo de 2024, sin que se hayan presentado nuevas alegaciones ni documentación tras la Propuesta de Resolución dictada por la instructora.

Por tanto, procede contestar únicamente a las alegaciones formuladas contra el acuerdo de inicio, en las que únicamente se aducían los siguientes motivos por los que se entendía que no cabía imputar responsabilidad a COYARE SLU (Bufete Ra) por la remisión del correo electrónico masivo al que se refiere este expediente:

- Cambio de interpretación del artículo 21.1 de la LSSI a raíz de la Sentencia de 15 de junio de 2011, que prohíbe el envío de comunicaciones comerciales que no hubieran sido solicitadas o expresamente autorizadas por sus destinatarios.

Según la reclamada, en dicha Sentencia, la A.N se aparta del requisito del consentimiento fijado por el artículo 21, y ha interpretado que en el caso de que un usuario recibiese varias comunicaciones comerciales de un tercero sin haber otorgado su consentimiento previo y expreso, pero sin oponerse al tratamiento, sólo sería sancionable la primera de las comunicaciones comerciales que se hubiese enviado, ya que al no haberse opuesto a la recepción de las siguientes comunicaciones comerciales, la AN considera que el usuario habría otorgado su consentimiento.

Se señala que, la Agencia Española de Protección de Datos (AEPD) ha comenzado a aplicar el criterio establecido por la AN desde septiembre de 2014, mencionando dos Resoluciones de la misma.

- Prescripción de las acciones y sanciones aplicables:

Se manifiesta al respecto que: *“Ante esta nueva interpretación de la LSSI, al ser únicamente la primera comunicación comercial la denunciante, si el usuario no se opusiese a las posteriores comunicaciones comerciales, cabría la posibilidad de que la acción para denunciar esa primera comunicación prescribiese, ya que el plazo de prescripción para las sanciones leves es de 6 meses desde la recepción de la primera comunicación (artículo 45 de la LSSI)”.* Entiende la reclamada que se trata de una infracción leve, por lo que estaría prescrita.

En este sentido, tal y como puso de manifiesto la Propuesta de Resolución, la parte reclamada no se defiende de las infracciones que son objeto del presente

procedimiento, y que se refieren a su incumplimiento como responsable del tratamiento de datos personales, de dos obligaciones establecidas en el RGPD, cuales son: (i) la obligación prevista en el artículo 5.1.f) del RGPD, por haber vulnerado el responsable su deber de confidencialidad de los datos personales de los destinatarios de estos correos, (ii) y del artículo 32 del RGPD por no haber previsto medidas de seguridad adecuadas que evitasen que dichos correos masivos se enviaran sin utilizar la funcionalidad de copia oculta.

Ambos argumentos contenidos en el escrito de alegaciones se defendían frente a un posible incumplimiento e infracción del artículo 21.1 de la LSSI, señalando que: (i) el bufete estaba legitimado para remitir la comunicación comercial del 23 de abril de 2023, sin necesidad de requerir previo consentimiento expreso de los destinatarios requerido por el citado precepto; (ii) y que la posible infracción del mencionado artículo 21 de la LSSI estaría prescrita, por ser, según su criterio, una infracción de carácter leve y prescribir a los 6 meses desde la remisión del correo electrónico.

No obstante, ni el Acuerdo de Inicio ni la Propuesta de Resolución del presente procedimiento sancionador han imputado nunca una infracción del artículo 21.1 de la LSSI. Es más, el Acuerdo de Inicio no hizo referencia alguna al hecho de que la remisión de dicho correo electrónico requiriese de previo consentimiento de los 95 destinatarios del mismo, cuestión no controvertida. Esta cuestión tampoco fue objeto de la reclamación interpuesta. Y la Propuesta de Resolución aclaró este particular, señalando claramente que los argumentos ofrecidos no se defendían frente a las infracciones realmente imputadas, y que por tanto, debían ser desestimados. No obstante, pese a ello, no se han presentado alegaciones tras la Propuesta.

Así pues, tal y como señaló la Propuesta de Resolución, y se suscribe por esta Resolución:

“Sin perjuicio de que los requisitos previstos en el mencionado precepto son aplicables a la remisión del correo electrónico al que se refiere el presente procedimiento, por cuanto que el mismo tenía un contenido comercial, lo que se está enjuiciando en este procedimiento es si la reclamada cumplió con los requisitos que el RGPD le impone para tratar los datos personales que fueron incluidos en copia ordinaria dentro de dicho correo electrónico.

Y a este respecto, dado que la reclamada ha reconocido haber remitido el correo electrónico a 95 destinatarios cuyas direcciones de correo aparecían visibles en copia ordinaria, no cabe lugar a dudas de que las infracciones imputadas han sido cometidas, dado que consta acreditado que:

- *La reclamada no cumplió con las obligaciones previstas en el artículo 5.1.f) del RGPD, al desvelar las direcciones electrónicas de 95 destinatarios al resto de los destinatarios del correo que no tenían derecho para acceder a tal información.*
- *La reclamada no disponía de las medidas de seguridad a las que se refiere el artículo 32 del RGPD, que impidieran la remisión de correos dirigidos a más de un destinatario, sin utilizar la funcionalidad de copia oculta.*

Cabe recordar, que en su escrito de 31 de julio de 2023, la reclamada manifestó lo siguiente: “que este despacho remite comunicaciones comerciales únicamente a los clientes que se registran en los diversos portales de pago a las que están suscritos como bufete de abogados y economistas, donde las personas que se suscriben registran sus datos personales, actuando al amparo del artículo 21 de la Ley 34/2002, de 11 de julio, sobre Servicios de la Sociedad de la Información (en adelante, LSSI).” Y junto con su escrito, se aportó por la reclamada la misma cabecera y cuerpo del email que fue aportado por el reclamante, lo que supone reconocer su contenido íntegro, incluido el hecho de que aparecían visibles las 95 direcciones de correo electrónico a las que se refiere el presente procedimiento.

Y en sus alegaciones de 3 de mayo de 2024 frente a este acuerdo de inicio, no niega que haya remitido dicho correo electrónico y se defiende de un posible incumplimiento del artículo 21 de la LSSI, lo que no es objeto de debate en el presente procedimiento, sin aportar prueba o argumento alguno que se refiera a las dos infracciones del RGPD cuya comisión son objeto de enjuiciamiento”.

Incluso tras realizarse esta aclaración, y teniendo la parte reclamada una oportunidad más para realizar alegaciones frente a la Propuesta de Resolución, y manifestarse acerca del presunto incumplimiento de los artículos 5.1.f) y 32 del RGPD, la misma no ha presentado alegaciones ni documentación alguna que contradiga los hechos probados en el presente procedimiento, incluso transcurridos más de 3 meses desde que la Propuesta le fue notificada.

Procede, por tanto, tras la instrucción practicada, tener por probados los hechos de los que se deriva el incumplimiento de ambas obligaciones de mantener la confidencialidad de los datos personales y adoptar medidas de seguridad adecuadas de la reclamada como responsable del tratamiento, y confirmar la comisión de las dos infracciones imputadas en el acuerdo de inicio del presente procedimiento sancionadora, en los términos que se recogen en los siguientes Fundamentos de Derecho de esta Resolución.

IV

Incumplimiento del artículo 5.1.f) del RGPD

Tal y como se ha indicado en los anteriores Fundamentos de Derecho, siendo aplicable el RGPD al tratamiento de los datos personales que han sido recogidos/registrados/extraídos y comunicados por COYARE SLU, con independencia del hecho de que el correo electrónico remitido tenga por contenido una comunicación comercial sometida a lo regulado en la LSSI, el responsable de los datos personales que se han incluido en dicho correo, está también sujeto al cumplimiento de los principios y obligaciones previstas en el RGPD.

Uno de los principios fundamentales es el denominado Principio de Confidencialidad de los datos, contenido en el artículo 5.1.f) “Principios relativos al tratamiento” del RGPD establece que:

“1. Los datos personales serán: (...)

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y

contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»).”

El artículo 4 apartado 12 del RGPD define, de un modo amplio, las “violaciones de seguridad de los datos personales” (en adelante brecha de seguridad) como “todas aquellas violaciones de la seguridad que ocasionen la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.”

En el presente caso, el correo electrónico masivo remitido el 24 de abril de 2023 a 95 destinatarios con publicidad comercial del Bufete-RA (COYARE SLU), ha supuesto una clara violación de seguridad o brecha de seguridad, calificada como “comunicación no autorizada” de los correos electrónicos de los destinatarios del correo que aparecen en copia ordinaria, por no haberse utilizado la funcionalidad de copia oculta, cometiendo con ello una infracción del principio de confidencialidad de estos datos regulado en el artículo 5.1.f) del RGPD.

Tal y como se ha expuesto anteriormente, la reclamada reconoce haber remitido el citado correo a todos los destinatarios que constan en el mismo, y no niega que sus direcciones de correo electrónico apareciesen en copia ordinaria, sin utilizar la funcionalidad de copia oculta. Y en ninguno de los escritos que ha presentado aporta prueba alguna ni argumentación relativa a la posible comisión de esta infracción, sino que, más bien al contrario, reconoce haber remitido el correo electrónico en estas condiciones, por lo que cabe confirmar que la reclamada vulneró el Principio de Confidencialidad, al desvelar estos datos personales (correo electrónico) a todos los que fueron incluidos como destinatarios del mismo en copia ordinaria, que no se hallaban autorizados para conocer los mismos.

En conclusión, de conformidad con los hechos probados en el presente procedimiento, se considera que la entidad reclamada ha cometido una infracción del artículo 5.1.f) del RGPD, por haber divulgado ilícitamente las direcciones de correo electrónico de los 95 destinatarios que aparecen visibles en el citado correo electrónico.

V

Tipificación y calificación de la infracción del artículo 5.1.f) del RGPD

La vulneración del artículo 5.1.f) del RGPD supone la comisión de la infracción tipificada en el artículo 83.5 del RGPD que bajo la rúbrica “Condiciones generales para la imposición de multas administrativas” dispone (el subrayado es nuestro):

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9; (...)”

A efectos del plazo de prescripción de las infracciones, cabe aplicar el artículo 72 “Infracciones consideradas muy graves” de la LOPDGDD, que indica (el subrayado es nuestro):

“1. En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679. (...)”

VI

Sanción por la infracción del artículo 5.1.f) del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el artículo 83.2 del RGPD.

“2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;

b) la intencionalidad o negligencia en la infracción;

c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;

d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;

e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;

f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;

g) las categorías de los datos de carácter personal afectados por la infracción;

h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;

i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;

j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y

k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción”.

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los criterios que establece el apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD:

“De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.
- f) La afectación a los derechos de los menores.
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado.”

En el presente supuesto, cabe aplicar las circunstancias de graduación siguientes:

- (i) La prevista en el artículo 83.2.a) del RGPD: “*La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido*”. Toda vez que el correo ha revelado un dato personal (correo electrónico) de 95 destinatarios.
- (i) La prevista en el art 83.2.b RGPD, relativa a: “*La intencionalidad o negligencia en la infracción*”, dado que pese a no concurrir dolo o intencionalidad, si se observa una falta grave de diligencia de la empresa responsable respecto a su deber de proteger la confidencialidad de los datos personales de las personas que fueron incluidas en este correo masivo sin ocultar su dirección de correo electrónico.

En este sentido el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto.

La STS de 5/06/1998 exige a los profesionales del sector “*un deber de conocer especialmente las normas aplicables*”. En similares términos se pronuncian, entre otras, las SSTs de 2/03/1999 y 17/09/1999, que establecen que las entidades que por su actividad están habituadas al tratamiento de datos personales deben ser especialmente diligentes y cuidadosas al realizar operaciones con ellos y deben optar siempre por la interpretación más favorable a la salvaguarda del derecho fundamental a la protección de datos (como de forma reiterada sostiene la Audiencia Nacional, entre otras en sentencia de 26/11/2008).

- (ii) La expuesta en el artículo 76.2 b) de la LOPDGD: “*La vinculación de la actividad del infractor con la realización de tratamientos de datos personales*”, puesto que la entidad COYARE SLU se dedica a prestar servicios de asesoramiento legal y económico a empresas y particulares, lo que es una actividad profesional sometida al deber de confidencialidad respecto de las personas inscritas en sus portales de pago, en los que se recoge numerosa información personal relativa a sus participantes.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y el artículo 76.2 de la LOPDGD, permite fijar la sanción de multa de **2.000 €** (DOS MIL EUROS) con respecto a la infracción cometida al vulnerar lo establecido en el artículo 5.1.f) del RGPD.

VII

Artículo 32 del RGPD

Todo responsable de operaciones de tratamiento de datos personales está sujeto al deber de prever adecuadas medidas técnicas y organizativas que sean necesarias para garantizar un nivel adecuado de seguridad de los datos personales que son objeto de tratamiento en su organización.

Así pues, el Artículo 32 “Seguridad del tratamiento” del RGPD establece lo siguiente:

“1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros: a) la seudonimización y el cifrado de datos personales; b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento; c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico; d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.

Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros”.

La reclamada ha reconocido en su escrito de 31 de julio de 2024 que ha remitido dicho correo electrónico masivo a 95 destinatarios desvelando sus direcciones de correo electrónico, al ponerlos en copia ordinaria, en lugar de utilizar la funcionalidad de copia oculta, tal y como debía ser esperable, lo que supone sin duda que la reclamada no actuó con la diligencia que le es exigible como responsable de tratamiento de dichos datos personales, toda vez que no había previsto las medidas de seguridad razonables en función de los posibles riesgos estimados que establece el citado precepto, dentro de las cuales estaba sin duda el impartir instrucciones y establecer un protocolo adecuado para evitar que los empleados y representantes que actúan en nombre de la entidad reclamada puedan en que se remitan estos correos masivos sin utilizar la función de copia oculta.

Situación que parece no haberse reparado en la actualidad, dado que la reclamada no alega ni acredita haber implantado ninguna nueva medida de seguridad dirigida a evitar que se remitan nuevos correos dirigidos a más de un destinatario sin utilizar la funcionalidad de copia oculta.

En conclusión, a la vista de los hechos probados en el presente procedimiento sancionador, se considera que los hechos conocidos vulneran lo establecido en el artículo 32 del RGPD, por no haber previsto las medidas de seguridad adecuadas al riesgo de divulgación ilícita que supone la remisión de correos electrónicos a múltiples destinatarios sin utilizar la funcionalidad de copia oculta.

VIII

Tipificación y calificación de la infracción del artículo 32 del RGPD

En virtud de lo indicado en el fundamento de derecho anterior, de conformidad con los hechos probados en el presente procedimiento sancionador, se considera que los hechos conocidos son constitutivos de una infracción administrativa por vulneración del artículo 32 del RGPD, por no establecer medidas adecuadas de seguridad que evitasen brechas como la producida en este supuesto.

La citada infracción del artículo 32 del RGPD supone la comisión de una infracción tipificada en el artículo 83.4 del RGPD que bajo la rúbrica “Condiciones generales para la imposición de multas administrativas” dispone lo siguiente (el subrayado es nuestro):

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

5) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (...)”

A efectos del plazo de prescripción de esta infracción, el artículo 73 “Infracciones consideradas graves” de la LOPDGDD indica:

“En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes: ...

f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679”.

IX

Sanción por la infracción del artículo 32 del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, procede graduar la sanción a imponer de acuerdo con los criterios que establece el artículo 83.2 del RGPD y el artículo 76 de la LOPDGDD.

En el presente supuesto, cabe aplicar las circunstancias de graduación siguientes:

- (i) La del artículo 83.2.a), referida a la “naturaleza, gravedad y duración de la infracción”, cabe señalar que estamos en presencia de una obligación esencial a cumplir por todo responsable del tratamiento de datos personales, y más cuando realiza operaciones de tratamiento masivo, como en el supuesto presente, habiéndose acreditado que se ha incumplido con una medida básica y notoriamente conocida en la actualidad, cual es el uso de la copia oculta para remitir correos masivos. Medida que no requiere una complejidad técnica de implementación, y que todos los empleados de la entidad deberían conocer para operar con datos personales.
- (ii) La prevista en el art 83.2.b RGPD, “la intencionalidad o negligencia en la infracción”, dado que todo responsable del tratamiento de datos personales debe ser consciente de su deber de prever adecuadas medidas técnicas y organizativas para proteger la seguridad y confidencialidad de los datos personales que traten, dado el Principio de Responsabilidad Proactiva del artículo 24 del RGPD, debiendo ser consciente y analizar los diversos riesgos derivados del tratamiento de estos datos y su impacto en los derechos y libertades de los interesados. Se entiende que existe imprudencia en el sentido establecido por el Tribunal Supremo, al que ya se ha hecho mención anteriormente.
- (i) La expuesta en el artículo 76.2 b) de la LOPPD: “La vinculación de la actividad del infractor con la realización de tratamientos de datos personales”, puesto que la entidad reclamada se dedica a prestar servicios de asesoramiento legal y económico a empresas y particulares, lo que es una actividad profesional sometida al deber de confidencialidad respecto de las personas inscritas en sus portales de pago, en los que se recoge numerosa información personal relativa a sus participantes.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y el artículo 76.2 de la LOPDGDD, permite fijar inicialmente la sanción de multa de **500 € (QUINIENTOS EUROS)** con respecto a la infracción cometida al vulnerar lo establecido en el artículo 32 del RGPD.

X

Adopción de medidas correctivas

Una vez confirmadas las infracciones, procede imponer al responsable la adopción de medidas adecuadas para ajustar su actuación a la normativa mencionada en este acto, de acuerdo con lo establecido en el citado artículo 58.2 d) del RGPD, según el cual cada autoridad de control podrá *“ordenar al responsable o encargado del tratamiento que las operaciones de tratamiento se ajusten a las disposiciones del*

presente Reglamento, cuando proceda, de una determinada manera y dentro de un plazo especificado...”

La imposición de esta medida es compatible con la sanción consistente en multa administrativa, según lo dispuesto en el art. 83.2 del RGPD.

En este caso, procede acordar la siguiente medida: la parte reclamada **deberá establecer y acreditar ante esta administración en el plazo de 1 mes** las medidas organizativas y técnicas que sean necesarias para evitar que en el futuro sea posible el envío de correos electrónicos con múltiples destinatarios, utilizando la funcionalidad “CCO” o cualquier otra que evite que la dirección de correo de cada destinatario sea conocida por el resto.

Entre otras, deberá acreditarse que se han establecido protocolos e impartido instrucciones a todos los miembros que remitan comunicaciones electrónicas en nombre de la entidad, al respecto de la necesidad de utilizar la funcionalidad de copia oculta y velar por la confidencialidad de los datos personales de cuyo tratamiento son responsables.

Se advierte que no atender la posible orden de adopción de medidas impuestas por este organismo en la resolución sancionadora podrá ser considerado como una infracción administrativa conforme a lo dispuesto en el RGPD, tipificada como infracción en su artículo 83.5 y 83.6, pudiendo motivar tal conducta la apertura de un ulterior procedimiento administrativo sancionador.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada, la Directora de la Agencia Española de Protección de Datos **RESUELVE**:

PRIMERO: IMPONER a **COYARE SLU (Bufete-RA)**, con NIF **B12931754**:

- Una sanción de multa de 2.000 € (DOS MIL EUROS), por una infracción del Artículo 5.1.f) del RGPD, tipificada en el Artículo 83.5 del RGPD.
- Una sanción de multa de 500 € (QUINIENTOS EUROS), por la comisión de una infracción del Artículo 32 del RGPD, tipificada en el Artículo 83.4 del RGPD.

SEGUNDO: ORDENAR a **COYARE SLU (Bufete-RA)**, con NIF **B12931754**, que en virtud del artículo 58.2.d) del RGPD, en el plazo de 1 mes desde que la presente resolución sea firme y ejecutiva, acredite haber procedido al cumplimiento de las siguientes medidas:

“Establecer y acreditar ante esta administración en el plazo de 1 mes las medidas organizativas y técnicas que sean necesarias para evitar que en el futuro sea posible el envío de correos electrónicos con múltiples destinatarios, utilizando la funcionalidad “CCO” o cualquier otra que evite que la dirección de correo de cada destinatario sea conocida por el resto.

TERCERO: NOTIFICAR la presente resolución a **COYARE SLU (Bufete-RA)**.

CUARTO: Esta resolución será ejecutiva una vez finalice el plazo para interponer el recurso potestativo de reposición (un mes a contar desde el día siguiente a la notificación de esta resolución) sin que el interesado haya hecho uso de esta facultad. Se advierte al sancionado que deberá hacer efectiva la sanción impuesta una vez que la presente resolución sea ejecutiva, de conformidad con lo dispuesto en el art. 98.1.b) de la ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante LPACAP), en el plazo de pago voluntario establecido en el art. 68 del Reglamento General de Recaudación, aprobado por Real Decreto 939/2005, de 29 de julio, en relación con el art. 62 de la Ley 58/2003, de 17 de diciembre, mediante su ingreso, indicando el NIF del sancionado y el número de procedimiento que figura en el encabezamiento de este documento, en la cuenta restringida nº **IBAN: ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)**, abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A.. En caso contrario, se procederá a su recaudación en período ejecutivo.

Recibida la notificación y una vez ejecutiva, si la fecha de ejecutividad se encuentra entre los días 1 y 15 de cada mes, ambos inclusive, el plazo para efectuar el pago voluntario será hasta el día 20 del mes siguiente o inmediato hábil posterior, y si se encuentra entre los días 16 y último de cada mes, ambos inclusive, el plazo del pago será hasta el 5 del segundo mes siguiente o inmediato hábil posterior.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa conforme al art. 48.6 de la LOPDGDD, y de acuerdo con lo establecido en el artículo 123 de la LPACAP, los interesados podrán interponer, potestativamente, recurso de reposición ante la Directora de la Agencia Española de Protección de Datos en el plazo de un mes a contar desde el día siguiente a la notificación de esta resolución o directamente recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

Finalmente, se señala que conforme a lo previsto en el art. 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

Mar España Martí
Directora de la Agencia Española de Protección de Datos

938-16012024